

Lab 11 - Bypass de MFA via AiTM



Prof. Dr. Luiz F. Freitas-Gutierrez

luiz.gutierrez@ufsm.br

linkedin.com/in/lffreitas-gutierrez



Lattes

ORCID

SciProfiles

Scopus

ResearcherID

substationworm

LFFreitasGutierrez

Resumo do problema

Hosts em contentores

- user-browser (victim workstation): The legitimate client system used by the operator to access the industrial web interface. This workstation is the target for credential harvesting and session compromise.
- phishing-proxy (AiTM phishing proxy): A malicious service that transparently relays communications between the victim workstation and the legitimate HMI server while capturing authentication credentials and session cookies.
- legit-hmi (authorized HMI server): The legitimate HMI system that provides operational control and monitoring services within the industrial environment.
- attacker (adversary): The threat actor who deploys and manages the phishing infrastructure in order to conduct credential theft, session hijacking, and access persistence.

Tarefas

- **1** Accede ao contentor vítima (user-browser) e abre o navegador web em modo texto com o seguinte comando: `elinks http://phishing.test`. O utilizador pensa que está a aceder ao sistema HMI legítimo; no entanto, na realidade, está a ligar-se a um domínio malicioso falsificado, concebido para se parecer muito com o endereço HMI autêntico.
- **2** Autentica-te usando as credenciais seguintes: operator (utilizador), otlab123 (palavra-passe), 000111 (código MFA). Depois da autenticação bem-sucedida, explora a interface web do HMI. Não termines sessão nesta fase.
- **3** Numa sessão de terminal separada, acede ao contentor atacante e executa este comando: `tail -f /loot/cookies.log`. O proxy de phishing intercetará e registará o cookie de sessão da vítima, permitindo contornar o MFA e tomar controlo da sessão.
- **4** Atribui o cookie capturado a uma variável chamada COOKIE no sistema atacante. Depois reutiliza o cookie para aceder à aplicação através do proxy de phishing: `curl -H "Cookie: ihhmsession=$COOKIE" -H "Host: phishing.test" http://172.30.0.20/home -L`. Espera-se acesso com sucesso sem confirmação MFA.
- **5** No sistema atacante, testa o acesso direto ao servidor HMI autorizado usando o cookie roubado: `curl -H "Cookie: ihhmsession=$COOKIE" http://legit-hhm:8000/home` OU `curl -H "Cookie: ihhmsession=$COOKIE" -H "Host: legit.test" http://172.30.10.40:8000/home`. Este passo simula um cenário de ataque em que um adversário reutiliza um token de sessão válido diretamente contra a infraestrutura legítima.
- **6** Efetua um logout global clicando em Log out na sessão de user-browser. Depois disso, tenta reutilizar novamente o cookie a partir do sistema atacante: `curl -i -H "Cookie: ihhmsession=$COOKIE" -H "Host: phishing.test"`

`http://172.30.0.20/home`. O pedido deve ser redirecionado para a página de login, indicando que a sessão é inválida.

Ferramentas

- As seguintes ferramentas estão disponíveis para completar o OTLab 11: `curl`, `elinks` e `tail`.

Nomenclatura

- AiTM: adversary-in-the-middle.
- HMI: interface homem-máquina.
- ICS: sistema de controlo industrial.
- MFA: autenticação multifator.
- OT: tecnologia operacional.
- SaaS: software como serviço.
- VPN: rede privada virtual.